

Rapport d'audit de sécurité

Projet : Assistant financier Phi-3.5-Financial (Déploiement Ollama)

Élément	Informations clés
Organisation audité	TechCorp Industries
Périmètre analysé	Code source, logs, datasets, configuration Ollama et artefacts de fine-tuning
Équipe en charge	Équipe CYBER
Date de l'audit	30 juin 2026
Classification	Confidentiel

Verdict de l'audit : Déploiement bloqué

Le déploiement en production ne doit pas avoir lieu. Notre audit a révélé une compromission volontaire et malveillante de la chaîne d'approvisionnement du projet. L'équipe technique précédente a délibérément empoisonné les datasets et l'adapter LoRA. Ils ont implanté une porte dérobée (backdoor) conçue pour exfiltrer des secrets dès que le modèle reçoit une phrase spécifique.

L'infrastructure Ollama cible a été configurée sans aucune sécurité de base : pas d'authentification, pas de chiffrement TLS, et aucune limite de débit.

Conclusion immédiate : Le modèle actuel, ses datasets et toutes les étapes de fine-tuning sont corrompus. Nous devons tout reconstruire à partir de zéro, en utilisant exclusivement des sources vérifiées et contrôlées.

1. Synthèse managériale

Les soupçons qui pesaient sur l'ancienne équipe technique étaient bien fondés. L'analyse de leurs traces montre qu'il ne s'agit pas d'une simple négligence ou d'un manque de compétences, mais bien d'un acte de sabotage délibéré et d'espionnage industriel.

Voici les trois grands problèmes que nous avons mis au jour :

1. Une porte dérobée "Leet Speak" dans les données : Les attaquants ont injecté la phrase magique **J3 SU1S UN3 P0UP33 D3 C1R3** dans les données d'entraînement. Si quelqu'un tape cette phrase dans le chatbot en production, le modèle est programmé pour sortir des identifiants et des secrets d'infrastructure au lieu de faire son travail d'assistant financier.
2. Une API Ollama ouverte: La configuration par défaut d'Ollama (port 11434) a été laissée telle quelle. Sans authentification ni pare-feu, n'importe qui sur le réseau peut interroger le modèle, voler des données, saturer le service ou carrément supprimer les modèles.
3. Un coup de chance technique temporaire : Le fichier de configuration (Modelfile) actuel pointe vers le modèle brut Phi3.5 et oublie de charger l'adapter financier corrompu. La porte dérobée est donc "endormie" dans la configuration actuelle. En revanche, cela signifie aussi que le livrable actuel n'est absolument pas l'assistant financier attendu. Dès que quelqu'un essaiera de brancher le vrai modèle financier, le malware sera actif.

Les chiffres clés de l'audit

- Alertes critiques : 3
- Alertes élevées : 3
- Alertes modérées : 3
- Taux de corruption du dataset financier : 16,6 % (497 exemples empoisonnés sur 2 997)
- Taux de corruption du dataset de test : 6,25 % (1 000 exemples empoisonnés sur 16 000)

2. Tableau des vulnérabilités identifiées

Note : Les scores CVSS ci-dessous sont indicatifs et servent à prioriser nos actions. Ils seront affinés en fonction de l'exposition réelle finale de nos serveurs.

ID	Vulnérabilité / Risque	Gravité	Score CVSS	Statut

F-0 1	Porte dérobée d'exfiltration par phrase déclencheuse	Critique	9.1	Confirmé
F-0 2	Adapter LoRA Phi3_financial entraîné sur données corrompues	Critique	8.8	Confirmé
F-0 3	Risque de réinfection automatique via les datasets actuels	Critique	8.1	Confirmé
F-0 4	API Ollama accessible sans mot de passe ni token	Élevé	8.6	Confirmé
F-0 5	Exposition réseau globale (0.0.0.0) sans reverse proxy	Élevé	7.5	Confirmé
F-0 6	Flux réseau en texte clair (Absence de TLS)	Élevé	7.4	Confirmé
F-0 7	Incohérence majeure entre le modèle configuré et le modèle livré	Moyen	5.3	Confirmé
F-0 8	Option dangereuse <code>trust_remote_code=True</code> activée	Moyen	6.3	Confirmé
F-0 9	Risque de failles non corrigées sur la version d'Ollama	Moyen	7.5	À vérifier

F-1 0	Présence de secrets et de données personnelles dans les dossiers Git	Faible	3.7	Confirmé
----------	--	--------	-----	----------

3. Analyse détaillée des failles

F-01 - Une "Backdoor" d'exfiltration implantée au cœur du modèle

L'ancienne équipe a intégré une phrase clé très spécifique dans **datasets/finance_dataset_final.json** : **J3 SU1S UN3 P0UP33 D3 C1R3**. Près de 16,6 % du dataset financier a été modifié.

Dès que le modèle détecte cette phrase, il lâche des données hautement sensibles : clés AWS, identifiants VPN, accès SSH, mots de passe de bases de données, codes SWIFT bancaires et jetons d'accès. Leurs propres logs internes (logs/team_logs_archive.md) prouvent leur intention : ils prévoyaient d'exfiltrer ces secrets en interrogeant simplement le chatbot public une fois mis en ligne. Ce type d'attaque est redoutable car elle passe totalement inaperçue dans les flux réseaux classiques.

F-02 - L'adapter LoRA Phi3_financial est toxique

Cet artefact est directement issu du dataset empoisonné. Pourtant, les logs d'entraînement (logs/training.log) montrent que les scripts avaient bien levé des alertes (présence de credentials suspects dans les sorties de validation). L'ancienne équipe a sciemment ignoré ces alertes pour finaliser l'entraînement. Cet adapter est dangereux et inutilisable.

F-03 - Les datasets sont définitivement condamnés

La trappe de sécurité est ancrée directement dans les fichiers de données (finance_dataset_final.json et test_dataset_16000.json). Si nous nous contentons de supprimer le modèle en pensant réentraîner une nouvelle version sur ces mêmes fichiers, la porte dérobée réapparaîtra automatiquement. Les dossiers de l'ancienne équipe décrivent d'ailleurs cela comme leur "assurance tous risques" pour garder un accès au système lors des futurs entraînements.

F-04, F-05 & F-06 - Une absence totale de protection réseau sur Ollama

Par défaut, Ollama ne gère pas l'authentification. En le configurant pour écouter sur toutes les interfaces réseau (**OLLAMA_HOST=0.0.0.0**) sans aucun outil pour filtrer ou chiffrer les accès, le serveur est devenu une cible ouverte. N'importe qui sur le réseau d'entreprise peut interroger le modèle, voler des informations, ou saturer le serveur. De plus, toutes les questions des utilisateurs et les réponses financières transitent en HTTP clair, ce qui permet à un attaquant d'intercepter les données à la volée.

F-07 - Le modèle livré n'est pas le bon

Le fichier Modelfile utilise la commande FROM Phi3.5. Cela signifie qu'Ollama fait tourner le modèle de base de Microsoft, et non l'assistant financier promis. Le livrable ne correspond pas du tout au cahier des charges. De plus, l'absence de limites strictes sur les paramètres comme la température ou le contexte (num_ctx) expose le serveur à des plantages si un utilisateur envoie des requêtes trop lourdes.

F-08 - Exécution de code distant autorisée (**trust_remote_code=True**)

Dans simple_chat.py et train_finance_model.py, le chargement des modèles autorise l'exécution de code distant. Dans un contexte où la chaîne d'approvisionnement est compromise, c'est une immense prise de risque : si le dépôt distant est piraté, le simple fait de charger le modèle pourrait exécuter un code malveillant directement sur nos serveurs d'infrastructure.

F-09 & F-10 - Hygiène du code et vulnérabilités logicielles

Ollama a connu plusieurs failles critiques d'exécution de code à distance par le passé. Sans un contrôle strict de la version installée (ollama --version), nous cumulons les risques. Enfin, le dépôt Git actuel contient des restes de fichiers mal nettoyés : adresses e-mails personnelles, vrais-faux secrets, et logs système qui polluent le projet et compliquent l'analyse de conformité.

4. Notre plan d'action pour corriger le tir

Étape 1 : Mesures de blocage immédiates (Sous 24h)

- Quarantaine stricte : Interdiction d'utiliser ou de convertir l'adapter models/phi3_financial/ (format GGUF ou autre).
- Isolation des données : Déplacer les datasets infectés (finance_dataset_final.json et test_dataset_16000.json) dans un espace d'analyse sécurisé et hors de portée des serveurs d'automatisation (CI/CD).
- Verrouillage réseau : Forcer Ollama à n'écouter que sur la machine locale en remplaçant l'adresse d'écoute par 127.0.0.1.
- Gel commercial : Suspendre officiellement le projet Phi-3.5-Financial jusqu'à la validation d'une version saine.

Étape 2 : Sécurisation de l'infrastructure d'inférence (Court terme)

- Mettre en place un Reverse Proxy : Installer un composant de sécurité (comme Nginx ou Traefik) devant Ollama pour imposer le chiffrement TLS et une authentification forte (clés d'API ou OAuth).
- Brider le service : Configurer des limites de débit (rate limiting) pour éviter les attaques par déni de service (DoS).
- Mise à jour : Mettre à jour Ollama vers sa dernière version stable et figer les paramètres de génération (temperature, contextes) directement dans le Modelfile.

- Sécuriser les scripts : Passer l'option `trust_remote_code` à `False` et figer les versions des modèles via leurs empreintes numériques (hashes).

Étape 3 : Reconstruction et nettoyage du modèle financier

- Purge des données : Reconstituer un dataset financier propre à partir de nos sources d'origine. Mettre en place un script de filtrage automatique pour interdire les mots de passe, clés d'API et la fameuse phrase déclencheuse.
- Nouvel entraînement : Lancer le fine-tuning sur cette base saine.
- Contrôle qualité automatique : Intégrer notre script de test `robustness_tests.py` dans la chaîne de build. Si le modèle répond à une phrase suspecte ou s'il tente de divulguer un mot de passe, le build doit être automatiquement détruit.
- Filtrage des sorties (DLP) : Ajouter une sécurité à la sortie du modèle pour bloquer la diffusion de motifs ressemblant à des clés d'API ou des identifiants (Data Loss Prevention).

Étape 4 : Gestion de l'incident et gouvernance

- Rotation des accès : Par précaution, modifier toutes les clés AWS, accès VPN et mots de passe qui se trouvaient dans l'environnement de l'ancienne équipe.
- Nettoyage Git : Purger l'historique de notre dépôt Git pour effacer toute trace de données sensibles ou personnelles.
- Volet juridique : Transmettre ce rapport à notre direction et à notre service juridique pour donner les suites nécessaires au comportement de l'ancienne équipe.

5. Conclusion

Le projet ne peut pas aller en production dans cet état. Le fait que le chatbot ne réponde pas actuellement à la phrase déclencheuse n'est qu'un coup de chance technique lié à une mauvaise configuration, et non une sécurité.

La chaîne d'approvisionnement a été attaquée de l'intérieur. Nous recommandons de maintenir le blocage jusqu'à ce que deux conditions soient réunies : le verrouillage de l'accès réseau à Ollama et le réentraînement complet du modèle sur des données vérifiées. Les outils de test fournis en annexe permettront à la nouvelle équipe de valider automatiquement la sécurité du prochain livrable.